Halotrcer report

Target http://127.0.0.1:18089/v1 · 2026-10-20 12:00 UTC · halotrcer test
Tokvera v0.1.0-dev (ok) · Sievant v0.1.0-157-gd8a8bcf (ok)

> tokvera v0.1.0-dev is outside the versions this release supports (>=0.2.0 <0.3.0)

Executive summary

Efficiency grade (Tokvera): F · Provisional scoring · reliability concern
Cost per 1,000 requests: $0.0471 (measured, rates as of 2026-10-20)
At your volume: $94.22 a month (2,000,000 requests/month you gave × measured cost)
Agent security (Sievant): 1 critical, 3 high · deal risk: 4 finding(s)

> Reliability concern: Tokvera graded this endpoint F. Shown beside the grade; it is not counted as deal risk.

Top 5 findings, ranked by business impact

1. Hard-coded Slack token
Sievant SEC001 · security · deal risk · server slack · env.SLACK_BOT_TOKEN · critical security finding (Sievant SEC001)
Fix: Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.

2. Literal value in secret-named field X-API-Key
Sievant SEC002 · security · deal risk · server api · headers.X-API-Key · deal risk: a customer security review would flag Sievant SEC002 (high)
Fix: Reference it from the environment (for example ${X_API_KEY}) and rotate it.

3. Credential embedded in the server URL
Sievant SEC004 · security · deal risk · server cap-remote · url · deal risk: a customer security review would flag Sievant SEC004 (high)
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

4. Credential embedded in the server URL
Sievant SEC004 · security · deal risk · server notes · url · deal risk: a customer security review would flag Sievant SEC004 (high)
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

5. Requests are failing
Tokvera error_rate · latency · Tokvera fail on latency, impact 30 grade points (at or above the median 30)
Fix: For 429s, raise the rate limit or add client-side retry with exponential backoff and jitter. For timeouts, compare the request timeout with the measured request duration. For 5xx, read the server logs at the times of the scan.

Cost & performance

From Tokvera: http://127.0.0.1:18089/v1 · model tokvera-sim-flaky

Efficiency grade: F (56.7 / 100, scoring 0.9.0)

Provisional scoring. The weights and thresholds are provisional: they have not yet been calibrated against real pilot scans and may change before scoring 1.0.0.
capped at F: more than 25% of requests failed
capped at D: more than 5% of requests failed
Requests: 24 sent, 9 succeeded, 15 failed, in 0.7 s.

Concurrency	Requests	Failed	TTFT p50	TTFT p95	TTFT p99	Duration p95
1	8	3	20.6 ms	20.8 ms	20.8 ms	98.5 ms
2	8	7	20.8 ms	20.8 ms	20.8 ms	98.5 ms
4	8	5	20.5 ms	20.5 ms	20.5 ms	98.3 ms

Cost

$0.0471 per 1,000 requests (estimate), rates as of 2026-10-20, source: halotrcer fixture (synthetic rate, not a real price)
At the 2,000,000 requests a month you gave: $94.22 a month (measured cost × your volume). This is spend, not a saving.

Findings

Requests are failing · fail · -30 grade points · effort 0.5–3 days

15 of 24 requests failed (HTTP 429 ×15)
Every failed request is either a user-visible error or a retry that costs latency and money. The status breakdown in the evidence says whether it is rate limiting, timeouts or server errors.
Fix: For 429s, raise the rate limit or add client-side retry with exponential backoff and jitter. For timeouts, compare the request timeout with the measured request duration. For 5xx, read the server logs at the times of the scan.

Failures rise at the highest concurrency · fail · -30 grade points · effort 1–3 days

5 of 8 requests failed at concurrency 4
The endpoint refuses or drops requests once enough arrive together, which is exactly when traffic peaks.
Fix: Size capacity or rate limits for the concurrency your traffic reaches, and make the client back off on 429 and 503 rather than retrying immediately.

No Prometheus metrics at /metrics · warn · -5 grade points · effort 0.5 days

no Prometheus exposition answered at /metrics on the target's origin
Queue depth, batch size and cache usage are what explain a latency problem. Without them, a slowdown can be seen but not diagnosed.
Fix: Enable the server's metrics endpoint (llama.cpp needs `--metrics`; vLLM and TGI serve /metrics by default) and scrape it. If the endpoint sits behind a gateway, expose the metrics there.

Tokvera contacts only the target you specify, plus GitHub when you run update or doctor --check-update, and tokvera.halotrcer.com and GitHub for the plugin's first-run install.
The load used Tokvera's fixed, harmless benchmark prompts. Response text was read for timing and discarded; none is stored in this report.

Agent security

From Sievant: the MCP server configuration of the AI clients on this machine.
custom · testdata/scan/cursor-mcp.json · file · 4 server(s), 4 not behind Sievant
custom · testdata/scan/vscode-mcp.jsonc · file · 2 server(s), 2 not behind Sievant
Findings: 1 critical, 3 high, 1 medium, 0 low, 0 info.

Critical: Hard-coded Slack token (SEC001) · deal risk

custom · testdata/scan/cursor-mcp.json · server slack · env.SLACK_BOT_TOKEN
Evidence (masked): xoxb… (28 chars)
Fix: Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.

High: Literal value in secret-named field X-API-Key (SEC002) · deal risk

custom · testdata/scan/vscode-mcp.jsonc · server api · headers.X-API-Key
Evidence (masked): lite… (21 chars)
Fix: Reference it from the environment (for example ${X_API_KEY}) and rotate it.

High: Credential embedded in the server URL (SEC004) · deal risk

custom · testdata/scan/cursor-mcp.json · server cap-remote · url
Evidence (masked): https://mcp.capability.example/apps/{masked:22}/mcp
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

High: Credential embedded in the server URL (SEC004) · deal risk

custom · testdata/scan/cursor-mcp.json · server notes · url
Evidence (masked): https://mcp.example.com/sse{masked:16}
Fix: Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.

Medium: Server runs with all permissions (Deno) (PERM003)

custom · testdata/scan/cursor-mcp.json · server deno · args[1]

Evidence (masked): --allow-all
Fix: Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).

Tool descriptions, and the resources and prompts each server offers, were not checked: that needs starting the servers (sievant scan --inspect-tools, which runs them).

Gateway coverage (sievant report, 30d)

unknown · controls enforced 7 of 12 · 0 requests, 0 blocked

High: No audit trail to report on
Fix: Run Sievant (sievant proxy through sievant wrap, or sievant serve) so it records calls, and point --audit at its store.

Medium: Wrapped servers allow every tool
Fix: Write a configuration (sievant init --profile balanced or strict), let it observe, then narrow it with sievant policy suggest and apply.

Low: Suspected prompt injection is recorded, not acted on
Fix: Set injection.action to annotate (the injection pack) or block for the agents that need it.

Low: Personal data in tool arguments is passed on
Fix: Set sanitization.input_pii to redact or block (pack secrets-pii).

Info: MCP client configurations were not checked
Fix: Run sievant report without --no-clients, or sievant scan.

This report describes how Sievant is configured and what its audit trail recorded in the period. It is generated by the software from local data; it is not a certification, an audit or an attestation, and it covers only the MCP traffic that passes through Sievant.

30-day fix plan

Week 1: critical exposure and quick fixes

• Hard-coded Slack token (Sievant SEC001)
Move it to the environment or a secret store and reference it (for example ${SLACK_BOT_TOKEN}); then rotate it, since it has been on disk.
• Literal value in secret-named field X-API-Key (Sievant SEC002)
Reference it from the environment (for example ${X_API_KEY}) and rotate it.
• Credential embedded in the server URL (Sievant SEC004)
Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
• Credential embedded in the server URL (Sievant SEC004)
Rotate the URL with the provider if it has been shared, keep the file private, and prefer a provider option that authenticates with a header referenced from the environment.
• No Prometheus metrics at /metrics (Tokvera metrics_endpoint)
Enable the server's metrics endpoint (llama.cpp needs `--metrics`; vLLM and TGI serve /metrics by default) and scrape it. If the endpoint sits behind a gateway, expose the metrics there.

Week 2: the largest cost and latency failures

• Requests are failing (Tokvera error_rate)
For 429s, raise the rate limit or add client-side retry with exponential backoff and jitter. For timeouts, compare the request timeout with the measured request duration. For 5xx, read the server logs at the times of the scan.
• Failures rise at the highest concurrency (Tokvera error_rate_at_peak)
Size capacity or rate limits for the concurrency your traffic reaches, and make the client back off on 429 and 503 rather than retrying immediately.

Week 3: remaining high-severity security findings

Nothing this week.

Week 4: everything else

• Server runs with all permissions (Deno) (Sievant PERM003)
Grant only the access the server needs (for Deno, --allow-net=<hosts>; for containers, a dedicated network).

How to read this report

Halotrcer's ranking across the two tools is provisional (scoring version 0.1.0): its tiers are judgement, not calibrated. See

docs/scoring.md.

Halotrcer contacts only the target you give it (through Tokvera) and reads only the MCP configuration files Sievant reads, on this machine. It sends no telemetry. Secrets stay masked as each tool masks them; on top of that, Halotrcer drops URL credentials and query strings, hides environment values, shows your home directory as ~ and replaces your user name with <user>.

Want a second pair of eyes? Book the AI Cost & Security Audit: https://www.halotrcer.com/book

Generated by halotrcer test · schema halotrcer.check-report/v1.0.0